SOHO 환경에서 MITRE ATT&CK 프레임워크를 사용한 Wi-Fi 라우터 무차별 대입 공격 시나리오 분석 및 방어 연구*

어윤규*, 이우곤*, 김태현*, 고성노*, 이규홍**, 이해영***, 남수만***

*청주대학교 (학부생)

**(주)팀솔루션 (연구원)

***청주대학교 (교수)

Analysis and Defense of Wi-Fi Router Brute-Force Attack Scenarios in SOHO Environments Using the MITRE ATT&CK Framework

Yun Gyu Eo*, Woo Gon Lee*, Tae Hyun Kim*, Sung No Go*,

Gyu Hong Lee**, Hae Young Lee***, Su Man Nam***,

*Cheongju University (Undergraduate student)

**TIM Solution (Researcher)

***Cheongju University (Professor)

요 약

본 연구는 MITRE ATT&CK 프레임워크를 이용해 SOHO 환경에서 Wi-Fi 라우터의 무차별 대입 공격 취약점을 분석했다. 분석 결과 확인된 원격 관리 노출, 부실한 계정 정책문제 등을 해결하기 위해 원격 접근 제한, 계정 잠금 정책 강화, 주기적 펌웨어 업데이트를 포함하는 다층적 방어 전략을 설계한다. 설계된 방어 체계의 유효성을 검증하기 위한 방법으로 MITRE Caldera를 활용한 자동화된 공격 시뮬레이션 모델을 제안한다.

I. 서론

SOHO(Small Office/Home Office)란 소규모 사무실이나 재택근무 환경을 의미한다. 이 환경에서 Wi-Fi 라우터는 원격 근무와 IoT 기기의 핵심 연결 허브로 활용되지만, 초기 관리자 계정 사용, 업데이트 미비, 불필요한 원격 관리 활성화 등으로 인해 공격자의 주요 표적이 되고 있다[1,2]. 따라서 무선 라우터는 소규모 네트워크 보안의 취약한 연결고리이다[3]. 이로 인해 관리자 권한 탈취, 개인정보 유출, 악성코드 확산 등 피해가 발생하며, DNS 하이재킹, 랜섬웨어 유포와 같은 2차 공격으로 이어질 수 있다.

본 연구는 무선 라우터를 대상으로 한 무차별 대입 공격(Brute-force attack)을 공격 기반의 위협 모델인 MITRE ATT&CK TTPs(Tactics, Techniques, Procedures)[4]를 통해 분석하고, MITRE Caldera 기반 공격 시뮬레이션을 수행하여 취약점을 검증하며 방어 전략을 제시한다.

연구의 기여는 다음과 같다.

- MITRE Caldera를 활용한 SOHO 라우터 공격 시뮬레이션 제안
- MITRE ATT&CK 프레임워크를 기반으로 한 SOHO IoT 환경 보안 취약점 분석 및 방어 전략 제시

이를 통해 SOHO 환경에서 라우터 중심 보안 체계 수립에 필요한 대응 방안을 제공한다.

* 본 연구는 2022년도 산업통상자원부의 기술개발사업 지원에 의한 연구임[RS-2022-00142509]

II. 배경 및 관련 연구

2.1 IoT 시스템의 보안 위협과 취약점

IoT 시스템은 자원의 한계로 인해 보안 취약성이 높아 다양한 공격에 노출된다. 실제로 국내외에서 무선 라우터 관련 보안 취약점 보고가 증가하고 있다[3]. 그 주요 원인은 초기 관리자 계정 방치, 취약점 미패치, 무차별 대입 공격 대응 미비 등 기초 보안 관리의 부재에 있다.

2.2 기존 취약점 분석의 한계

표 1. 기존 취약점 분석 방법론 비교

구분	정적분석 (White-box)	동적분석 (Black-box)	모의해킹 (Black/White /Gray-box)
대상	소스 코드, 바이너리	실행 중 애플리케이션	시스템·네트워크·애플리케이션
시점	개발 초기	테스트/운영 단계	테스트/운영 단계
장점	초기 취약점 발견 용이	환경 설정 오류 발견	실제 공격과 유사, 응용성 높음
한계	공개 취약점 중심, 최신 위협에 취약	외부 현상만 확인, 최신 위협에 취약	일회성 점검, 최신 위협에 취약

표 1은 기존의 취약점 분석 방법론을 비교한다. 정적분석은 공개된 취약점을 중심으로 탐지하고, 동적분석은 외부로 드러난 현상만 확인하는 수준이다. 모의해킹 역시 특정시점의 일회성 점검이라는 한계가 있어, 기존의 방법으로는 여러 단계로 진행되는 최신 위협의 흐름을 파악하기 어렵다. 따라서 MITRE ATT&CK TTPs 등과 같은 다양한 공격 시나리오를 통해 효율적인 대응이 필요하다.

2.3 MITRE Caldera 플랫폼

MITRE Caldera는 공격 시나리오를 실제 시스템에서 자동으로 실행하여 방어 체계의 효과를 검증하는 공격 플랫폼이다. 이때 사용되는 공격 시나리오는 실제 공격자의 행위를 TTPs로 체계화한 MITRE ATT&CK을 기반으로 한다[5]. 기존의 정적·동적 분석이나 모의해킹은 개별 취약점 탐지에는 유용하지만 공격자의 연속적 행위를 재현하기에는 한계가 있다. 그러나 Caldera는 실제 공격 시나리오를 최소한의 비용과 인력으로 지속 검증하여 위협 정보 기반 방어(Threat-Informed Defense)를 구현하는 대안을 제공한다.

III. MITRE Caldera를 사용한 공격 시나리오 모델

3.1 개요

본 장에서는 무선 라우터에 대한 무차별 대입 공격 시나리오를 분석하는 것을 목표로 한다. 시나리오 설계 단계는 다음 4단계로 구성된다.

1. **가상 환경 정의:** 공격 시나리오의 기반이 되는 네트워크 토폴로지와 구성 요소를 정의
2. **공격 시나리오 모델링:** 공격 시나리오를 사이버 킬체인 모델 기반으로 구체화
3. **ATT&CK TTPs 매핑 및 분석:** 각 공격 행위를 MITRE ATT&CK 프레임워크에 매핑하여 구조적으로 분석
4. **연속적 공격 방안 설계:** 매핑된 TTPs 기반 Caldera를 활용한 연속적 공격 체계 설계

3.2 공격 시나리오 모델

우리는 SOHO 환경에서 무선 라우터에 무차별 대응 공격을 시도하고 이를 분석하기 위해 첫째로 가상 환경을 정의한다. 이 가상 환경의 구성 요소는 다음과 같다.

- **공격자 시스템:** Kali Linux 등 공격 도구가 설치된 외부 가상머신
- **인터넷:** 공격자와 대상 라우터 간의 통신이 이루어지는 공용 네트워크
- **SOHO Wi-Fi 라우터:** 관리자 페이지가 외부에 노출된 취약한 상태의 공격 대상 요소
- **내부 네트워크 장치:** 라우터에 연결된 IoT 기기, PC, 스마트폰 등 내부 자산 요소

둘째, 생성된 가상머신에서 사이버 킬체인(Cyber Kill Chain)에 따라 공격 시나리오를 다음과 같이 제시한다.

1. **정찰(Reconnaissance)**: Nmap 등 스캐닝 도구로 노출된 라우터의 관리 페이지 탐색
2. **무기화(Weaponization)**: Hydra 등 자동화 도구와 사전(password list)을 준비
3. **전달 및 공격(Delivery & Exploitation)**: 대량의 로그인 요청을 통한 관리자 계정 탈취
4. **설치 및 지속성(Installation & Persistence)**: 관리자 암호 변경, 로그 삭제 및 흔적 제거
5. **명령·제어 및 목표 달성(Command & Control, Actions on Objectives)**: 웹을 통해 라우터를 원격 제어하고 DNS 변경 등 2차 공격을 수행

셋째, 사이버 킬체인(Cyber Kill Chain)을 통해 MITRE ATT&CK TTPs에 매핑하여 공격 행위를 분석한다.

표 2. MITRE ATT&CK TTPs 매핑

사이버 킬체인 (Cyber Kill Chain)	전술 (Tactic)	공격 기술 (ATT&CK ID)	설명
Reconnaissance	Reconnaissance	T1595.001 - Active Scanning: Scanning IP Blocks	외부에 노출된 라우터 관리자 페이지 탐색
Delivery & Exploitation	Initial Access	T1110.001 - Brute Force: Password Guessing	자동화된 도구로 관리자 계정 정보 탈취 시도
Delivery & Exploitation	Persistence	T1098 - Account Manipulation	관리자 암호를 변경하여 지속적인 제어권 확보
Installation	Defense Evasion	T1070.007 - Indicator Removal	시스템 로그를 삭제하여 공격 흔적 제거 및 탐지 회피
Command & Control	Command & Control	T1071.001 - Application Layer Protocol: Web Protocols	HTTP/HTTPS를 통해 원격 명령 및 제어 수행
Actions on Objectives	Impact	T1499 - Endpoint Denial of Service	라우터 설정을 변경하여 정상 통신 방해 및 2차 공격 준비

표 2는 무선 라우터 무차별 대입 공격에 대한 MITRE ATT&CK TTPs 매핑이다. 분석 결과, 공격은 기본 보안 관리의 허술함을 연속적으로 이용한다. 즉 관리자 페이지가 외부에 열려 있는 설정 오류(T1595.001), 약한 비밀번호 정책(T1110.001), 계정 및 로그 무결성 관리 부족(T1098, T1070.007), 그리고 원격 통신 과정에서의 이상 행위 탐지 한계(T1071.001)와 같은 문제들이 연결되어 취약점이 노출되었다.

넷째, Caldera를 활용하여 매핑된 TTPs를 기반으로 연속적인 공격을 수행할 수 있다. 이 연속 공격 체계는 실제 위협처럼 전개되는 공격을 시뮬레이션하여, 전체 공격 흐름을 이어갈 뿐만 아니라 이후 공격 전략을 설정할 수도 있다.

IV. 공격 시나리오에 따른 대응 방안

4.1 방어 시나리오

3장에서 제시한 공격 시나리오 분석을 토대로 본 장에서는 공격 시나리오를 효과적으로 방어하기 대응 방안을 제안한다.

표 3. ATT&CK 기술에 매핑된 방어적 대응 방안

공격 기술 (ATT&CK ID)	권장 대응 방안	우선 순위
T1595.001 - Scanning IP Blocks	원격/WAN 관리 기능 비활성화	최고
T1110.001 - Password Guessing	강력하고 고유한 관리자 계정 정보 사용	최고
T1110.001 - Password Guessing	계정 잠금 정책 활성화	높음
N/A (전반적 취약점 대응)	펌웨어 최신 버전 유지	높음
T1070.007 - Indicator Removal	로그 외부 전송(Syslog)	중간
T1098 - Account Manipulation	설정 변경 알림 기능 활성화	중간
T1090 - Proxy (Lateral Movement)	게스트 네트워크를 통한 망 분리	높음
N/A (내부 전파 경로 차단)	UPnP 기능 비활성화	높음
T1499 - Endpoint Denial of Service	설정 파일 백업	중간

표 3은 ATT&CK 기술에 매핑된 방어 시나리오이다. 무선 라우터의 주요 위협에 대응하기 위해 기본 보안 설정 강화를 중심으로 구성되었다. 원격 관리 차단, 계정 정책 강화, 펌웨어 최신화 등 기초적인 조치가 핵심 방어 수단임을 보여주며, 이는 복잡한 기술보다 기본 수칙을 철저히 준수하는 것이 보안 체계 구축에 효과적임을 보여준다.

4.2 Caldera 기반 자동화된 공격 대응

Caldera는 공격(Red Team)뿐만 아니라 대응(Blue Team)까지 자동화가 가능하다. 내장된 'Response' 플러그인을 통해 특정 공격 기법이 탐지되면 그에 따른 대응 절차를 자동으로 실행하도록 구성할 수 있다. 이러한 자동화된 대응 체계는 반복적인 위협을 신속하게 처리 할 수 있고, 인적 자원을 최소화해 효율적인 운영을 가능하게 한다[6].

V. 결론 및 향후 연구

본 연구는 SOHO Wi-Fi 라우터에 대한 무차별 대입 공격을 MITRE ATT&CK TTPs 관점에서 분석했다. 분석 결과, 공격 성공의 핵심 요인이 기본적인 보안 관리 부실에 있다. 이는 무선 라우터가 지속적이고 체계적인 관리가 반드시 필요한 중요 보안 자산임을 보여준다. 또한 도출된 공격 시나리오에 대응하기 위해 다층 방어 전략을 제시했으며, Caldera 플랫폼이 위협 정보 기반 방어에 효과적으로 활용 가능하다.

향후 제조업체 차원에서 초기 비밀번호 변경 의무화, 원격 관리 기능 기본 비활성화 등 보안이 강화된 출고 설정을 산업 표준으로 확립하는 정책 개발을 할 예정이다[1]. 나아가 SOHO 환경을 넘어 스마트공장과 같은 대규모 환경에서도 적용 가능한 보안 체계를 마련하고, 최신 위협(예: 랜섬웨어 등)에 효과적으로 대응하기 위한 연구를 지속할 것이다[7].

[참고문헌]

[1] Evaluators, I.S., SOHO Network Equipment Security Evaluation, Independent Security Evaluators, 2017.

[2] 배희라, 김민영, 송수경, 이슬기, 장영현. (2016). 무선공유기 보안공격 분석 및 무료 와이파이 해킹 해결방안. 문화기술의 융합, 2(4), 65-70.

[3] 김철홍, 정임영. (2016). SOHO환경을 위한 스마트 무선 침입 탐지 시스템 구현. 한국콘텐츠학회 논문지, 16(10), 467-476.

[4] "MITRE ATT&CK Enterprise Techniques". IBM, https://https://attack.mitre.org/techniques/ent

[5] "Mitre | CALDERA". MITRE. https://caldera.mitre.org/erprise/

[6] Jiang, Y., Meng, Q., Shang, F., Oo, N., Minh, L.T.H., Lim, H.W. and Sikdar, B., MITRE ATT&CK Applications in Cybersecurity and The Way Forward, arXiv arXiv:2502.10825, February 2025.

[7] 남수만, 이승민, 박영선. (2021). 디지털트윈 기반의 스마트공장에서 랜섬웨어 공격과 피해 분석을 위한 정보보안 실습콘텐츠 시나리오 개발. 정보보호학회논문지, 31(5), 1001-1010.